# Основе информационе безбедности — Контролне тачке

## КТ1 Основна имплементација и безбедносни модел

Термин: Вежба 4

Прва контролна тачка одржава се у термину 4. вежбе. Тим приказује обухват свих додељених целина, безбедносни модел и први заокружен функционални ток са серверском заштитом и негативним тестом.

### Обавезно за све тимове

1. За СВАКУ додељену целину: листа случај употребе-ова из спецификације, редослед имплементације и означени предуслови (Тапиз листа планираних задатака).

2. Један обједињени домен модел / скица тока, кључни ентитети, статуси и власништво података; минимална сецурити матрица Субјецт–Ацтион–Ресоурце–Allow/Deny за релевантне операције.

3. Репозиторијум: основна структура апликације, РЕАДМЕ са стартовањем, изградња који пролази, почетни Континуирана интеграција и Тапиз задатак → бранцх → ПР пракса.

4. Примарна целина: најмање један заокружен функционалан ток који пролази кроз апликациону логику и persistence/simulator, са демонстрацијом нормалног исхода; за једноставније целине очекују се бар две кључне операције (нпр. унос + промена статуса).

5. Серверска заштита конкретне операције (scope/ownership/role према домену), валидација улаза и један АУТОМАТИЗОВАН негативни тест; не сматра се довољном заштита само кроз УИ.

6. Тхреат модел свих додељених целина: ассет → misuse/pretnja → контрола → тест → евиденце, уз приказ бар једне труст границе.

7. Migracije/seed или еквивалентно поновљиво тестно стање; структурисани događaj/audit за релевантну промену без тајни.

8. Минимални међутимски уговор прегледан са суседним тимом; ако имплементација није спремна, заменска компонента + позитивни и негативни одговор.

### Приказ

Модел и листа планираних задатака, покренут нормалан сценарио, негативан аутоматски тест и конкретан план завршетка до КТ2 у термину 8. вежбе.

### Не тражити у овој фази

- Пуна реализација druge/treće целине.
- Продукциони симулатор.

## КТ2 Завршна демонстрација и провера безбедносног квалитета

Термин: Вежба 8

Друга контролна тачка одржава се у термину 8. вежбе. Тим демонстрира све обавезне случајеве употребе свих додељених целина у одобреном обиму, њихово повезивање, безбедносне одлуке и поновљиво покретање, уз ажурну документацију.

### Обавезно за све тимове

1. Сви обавезни случајеви употребе АКТIVNOG/ODOBRENOG обухвата целина; ако се пуни нормативни обухват из СКУТУМ спецификације смањује, НАСТАВНИ ТИМ мора то унапред експлицитно објавити као ревизију.

2. Енд-то-енд демо: почетно стање → акција → одлука dozvoli/odbij → релевантан security/audit траг → коначан статус.

3. Унит + негативни сецурити + одговарајући integracioni/contract тестови по релевантној целини, Континуирана интеграција греен, документоване ревизије ПР.

4. Цлеан цлоне, миграције и seed/demo подаци раде према РЕАДМЕ-у.

5. API/event/policy уговори, тхреат модел, Записи о архитектонским одлукама, евиденција тестирања, индивидуални доприноси и ресидуал риск су ажурни.

6. Међутимски интеграција са реалним адаптером где је доступна; само заменска компонента не приказивати као завршену реалну интеграцију.

## Додатно за тимове са 3 целине

1. Трећа целина мора имати јавно одобрен опсег и извршив безбедносни ток са аутоматизованим тестовима; комплетан нормативни обим је обавезан осим ако је наставни тим формално променио спецификацију.

## Приказ

Повезани енд-то-енд сценарио, позитиван и негативан тест, уговори и индивидуално образложење рада. Контролне тачке и термини одбране пројекта су одвојене обавезе.